

Day 01

Cybersecurity Fundamentals

CIA Triad • Threats • Cryptography • NIST / ISO / CIS

Preventive Surveillance in Cybersecurity

CYBER.SOHO

*From the Industry
to the Classroom*

*Building the IT's Future,
Today and Together!*

Competency EZ01

Today's Agenda

- Lecture 1 — CIA Triad and Cyber Threat Types (60 min)
- Exercise / Case Study 1 — Recent Cyber Incidents (45 min)
- Lecture 2 — Cryptography + NIST / ISO / CIS (60 min)
- Exercise / Demo 2 — Build Topology in AWS / VirtualBox / GNS3 (45 min)

All artefacts produced today seed Lab 0 — Foundations of your Course Procedure Manual.

LECTURE 1

The CIA Triad

Confidentiality • Integrity • Availability

Confidentiality

- Definition — only authorized eyes see the data
- Failure modes — leaked DB, plaintext logs, lost laptop
- Mechanisms
 - Encryption at rest (BitLocker, LUKS, S3-SSE)
 - Encryption in transit (TLS 1.3, WireGuard)
 - Access Control Lists (ACL) & Role-Based Access Control (RBAC)
 - Multi-Factor Authentication (MFA)
 - Principle of Least Privilege — default deny, then add

KEY TAKEAWAY • Need-to-know is the rule — least privilege is how you enforce it.

Integrity

- Definition — data read = data written, no unauthorised change
- Failure modes — tampered config, edited log, malicious update
- Mechanisms
 - Cryptographic hashes — SHA-256, SHA-3, BLAKE3
 - Digital signatures — RSA, ECDSA, Ed25519
 - Code-signing certificates
 - File Integrity Monitoring (FIM) — AIDE, OSSEC
 - Immutable / write-once-read-many logging

KEY TAKEAWAY • If one byte changed, the hash changed — that's the avalanche effect.

Availability

- Definition — reachable when authorised users need it
- Failure modes — DDoS, ransomware, mis-cabling, capacity collapse
- Mechanisms
 - Redundancy — RAID, clustering, multi-AZ
 - Geographic load balancing & failover
 - DDoS protection — Cloudflare, AWS Shield
 - Tested backups (untested ≠ backups)
 - Capacity planning & autoscaling

KEY TAKEAWAY • An offline system is a security failure even if it's encrypted.

The CIA Triad — Synthesis

- Every security control on Earth ultimately props up C, I or A
- Most breaches violate two legs at once (e.g., ransomware = A + C)
- Each leg has its own dedicated toolkit, but they overlap
- Recognising which leg is under attack drives the response playbook

KEY TAKEAWAY • Lose a leg, the stool falls. Defence = keeping all three standing.

Principle of Least Privilege

- Default deny → then grant the minimum needed
- Codified in NIST SP 800-53 control AC-6
- Applies to users, services, processes, networks, and APIs
- Most real-world breaches trace back to violating this principle
- Cheap to implement — high impact across all three CIA legs

KEY TAKEAWAY • Least privilege is the highest ROI security control you'll ever ship.

"AVAILABLE" IS A NUMBER, NOT A FEELING

Availability Targets

Tier	Uptime %	Downtime / year	Downtime / month
Basic	99 %	3 d 15 h	7 h 18 min
Standard	99.9 %	8 h 45 min	43 min
High	99.99 %	52 min	4.3 min
Critical	99.999 %	5.3 min	26 sec

KEY TAKEAWAY • Pick a tier the business can afford, then engineer to it.

Cyber Threat Bestiary (1/4)

Type	Behaviour	Real example
Virus	Infects host file, runs when host runs	ILOVEYOU (2000)
Worm	Self-propagates, no user action needed	WannaCry (2017)
Trojan	Disguised as legitimate software	Emotet
Ransomware	Encrypts files, demands payment	LockBit, Conti
Spyware	Silently exfiltrates user activity	Pegasus
Rootkit	Hides at OS or firmware level	Stuxnet component
Cryptojacker	Mines crypto on victim CPU/GPU	Coinhive
RAT	Remote Access Trojan — full control	DarkComet, NjRAT

Cyber Threat Bestiary (2/4)

- DoS / DDoS — Denial of Service / Distributed DoS
 - Flood until legitimate users cannot reach the service
- MITM — Man-In-The-Middle
 - Sit between two endpoints, intercept or modify traffic
- ARP spoofing
 - Abuse Address Resolution Protocol to redirect LAN traffic
- DNS poisoning / hijacking
 - Corrupt DNS responses to redirect victims to malicious sites
- Port scanning / enumeration
 - Reconnaissance step preceding most attacks

Cyber Threat Bestiary (3/4)

- Phishing — mass deceptive email for credentials or payment
- Spear phishing — targeted, personalised version of phishing
- Whaling — spear phishing aimed at executives
- Vishing / Smishing — voice-phone and SMS variants
- Business Email Compromise (BEC) — exec impersonation, wire fraud
- Pretexting — invented scenario to extract information
- Watering-hole — compromise a site the target group visits

Cyber Threat Bestiary (4/4)

- Application-layer
 - SQL Injection (SQLi) — inject DB commands via input
 - Cross-Site Scripting (XSS) — inject scripts into another browser
 - Cross-Site Request Forgery (CSRF) — abuse session of logged-in user
 - Server-Side Request Forgery (SSRF) — server makes attacker requests
 - File-upload abuse — drop executable content on misconfigured server
- Strategic / supply-chain
 - Supply-chain compromise — vendor's update mechanism (SolarWinds)
 - Insider threat — malicious or negligent legitimate user
 - Zero-day — exploit before any patch exists

KEY TAKEAWAY • You cannot defend against what you cannot name. Memorise this bestiary.

Threat → CIA Mapping (1/2)

Threat	Primary CIA leg	Typical defence
Ransomware	Availability (and Confidentiality)	Tested offline backups, EDR
DDoS	Availability	Anycast, scrubbing, rate-limit
SQL Injection	Confidentiality + Integrity	Parameterised queries, WAF
Phishing	Confidentiality	MFA, training, email gateway
MITM	Confidentiality + Integrity	TLS, certificate pinning

Threat → CIA Mapping (2/2)

Threat	Primary CIA leg	Typical defence
Insider data theft	Confidentiality	DLP, least privilege, UEBA
Supply-chain attack	C + I + A (all three)	SBOM, code-signing, vendor risk
XSS	Integrity + Confidentiality	Output encoding, CSP headers
BEC	Confidentiality + Integrity	DMARC, dual approval, training
Brute-force SSH	Confidentiality	Key-only auth, fail2ban, MFA

KEY TAKEAWAY • Defence is a mapping problem: threat → CIA leg → control.

Performance vs Security

- Every control has a cost: CPU, disk, latency, money
- Encryption uses CPU — logging uses disk — DPI adds latency
- Goal is balance, not maximum security
- Risk appetite — how much risk the business will tolerate
- Document your trade-offs — auditors will ask

KEY TAKEAWAY • Perfect security is unplugged & useless. The job is the middle.

Exercise 1 — Recent Cyber Incidents

- Investigate three real incidents and map them to CIA + threat type
 - MOVEit / ClOp mass exploitation (2023)
 - Change Healthcare ransomware (2024)
 - XZ Utils backdoor — CVE-2024-3094
- For each: who, when, how, what was lost, CIA mapping, mitigation
- Screenshot every source — verify URLs on VirusTotal first
- Deliverable — PDF with screenshots, comparative summary, references
- Due May 10, 23:59 EST — Omnivox LEA Dropbox • Goes into Lab 0

KEY TAKEAWAY • Real incidents are the laboratory of theory. Read them like autopsies.

LECTURE 2

Cryptography & Frameworks

Primitives • NIST • ISO 27000 • CIS

Symmetric Encryption

- Same secret key encrypts and decrypts
- Fast — gigabytes per second on modern CPU
- Bootstrap problem — how do both sides get the key?

Algorithm	2025 status	Typical use
AES-128, AES-256	Recommended	BitLocker, LUKS, TLS body, S3-SSE
ChaCha20	Recommended	Mobile TLS, WireGuard VPN
3DES (Triple DES)	Deprecated	Legacy banking only
DES, RC4	Broken	Never use

Asymmetric Encryption

- Mathematically related key pair (public + private)
- Encrypted with one → only the other can decrypt
- Slow — used for key exchange & digital signatures, not bulk data

Algorithm	Status	Typical use
RSA-2048 / RSA-3072	Acceptable	TLS certificates, PGP
ECDSA, Ed25519	Recommended	TLS, SSH keys, code-signing
RSA-1024	Broken	Never
Post-quantum (ML-KEM, ML-DSA)	Standardised 2024	Future-proofing

Hash Functions

- One-way — fixed-length fingerprint of any input
- Cannot be reversed — that's the whole point
- Used for integrity, password storage (with salt), digital signatures

Function	Status	Notes
SHA-256, SHA-3-256	Recommended	Default for everything
BLAKE2, BLAKE3	Recommended	Faster than SHA-2
SHA-1	Broken (collisions)	Avoid; still in Git for now
MD5	Fully broken	Never for security

KEY TAKEAWAY • Asymmetric to bootstrap, symmetric for bulk, hash for integrity = TLS.

Password Hashing — Don't Botch It

- Plain SHA-256 of a password = BROKEN
 - No salt → identical passwords give identical hashes
 - Too fast → 10 billion guesses / sec on a GPU
- Use a slow Key Derivation Function (KDF)
 - bcrypt — battle-tested since 1999
 - scrypt — memory-hard variant
 - Argon2id — OWASP #1 recommendation since 2021
- Per-user random salt is mandatory, embedded in the hash

KEY TAKEAWAY • Speed is the enemy when hashing passwords. Slow on purpose, salted always.

NIST — National Institute of Standards & Technology

- Cybersecurity Framework (CSF) 2.0 — six functions
 - Govern • Identify • Protect • Detect • Respond • Recover
 - Lingua franca for risk discussions with non-tech executives
- SP 800-53 — catalogue of 1,000+ security controls in 20 families
 - AC = Access Control, AU = Audit, IR = Incident Response, ...
- SP 800-61 — gold-standard incident-response playbook
- National Vulnerability Database (NVD) — every CVE in one searchable place

KEY TAKEAWAY • Free, US federal, ubiquitous — start every security conversation here.

ISO / IEC 27000 Series

- Joint output of ISO + IEC — recognised worldwide
- ISO/IEC 27001:2022 — the certifiable Information Security
 - Management System (ISMS) standard
 - Means an external auditor confirmed the company runs
 - security as a continuous process — not a one-off
- ISO/IEC 27002:2022 — catalogue of 93 controls referenced by 27001
- Standards documents themselves are paid — controls are widely summarised free

KEY TAKEAWAY • If a vendor says "ISO 27001 certified", that's process maturity, not perfection.

CIS — Center for Internet Security

- CIS Critical Security Controls v8.1
 - 18 prioritised controls — start here if you have nothing
 - Implementation Groups IG1, IG2, IG3 by org size & maturity
- CIS Benchmarks
 - Line-by-line hardening guides for 100+ platforms
 - Windows, Linux, macOS, AWS, Azure, GCP, Cisco IOS, Kubernetes...
 - Free PDF behind an email wall — paid automated tooling

KEY TAKEAWAY • Pragmatic, prioritised, free. The fastest path from 0 → defensible.

Frameworks Cheat Sheet

When you need to...	Reach for
Brief a non-technical CEO on risk	NIST CSF 2.0
Pick specific controls for a US-regulated system	NIST SP 800-53
Get a certifiable management system	ISO/IEC 27001
Know exactly what to do *first* with limited budget	CIS Controls v8.1
Harden a specific OS or product line by line	CIS Benchmarks
Map an incident chronology	NIST SP 800-61 / MITRE ATT&CK

KEY TAKEAWAY • Audience and goal pick the framework — not personal preference.

Risk = Likelihood × Impact

- Likelihood — based on threat intel and historical incidents
- Impact — based on business value at stake (€, reputation, legal)
- Score every asset × threat pair on a 1-5 scale
- Sort the table by risk score — top of the list gets controls first
- Residual risk — what remains after controls; compare to risk appetite

KEY TAKEAWAY • Score it, sort it, fund the top of the list. Repeat quarterly.

Risk Register — Worked Example

Asset	Threat	L	I	Score	Mitigation control
Patient DB	Ransomware	4	5	20	Tested offline backups + EDR
Public website	DDoS	3	3	9	Cloudflare WAF + autoscaling
Employee laptops	Phishing	5	3	15	MFA + email gateway + training
Domain controller	Lateral mvmt	3	5	15	Tiered admin model + MFA
Backup server	Insider theft	2	5	10	DLP + least privilege + monitoring

Exercise 2 — Build the Lab Topology

- Build the SAME minimalist topology in three platforms
 - AWS Educate — cloud, free for students
 - VirtualBox — local, offline, hands-on
 - GNS3 — network-emulation realism with pfSense
- 1 router + 3 hosts (Win-Server, Linux-Server, Analyst-VM) on 10.0.0.0/24
- In class — pick one platform. At home — finish the other two.
- Deliverable — PDF with screenshots, platform-comparison table, lessons-learned
- Reused as the environment chapter for Labs 1 → 6

KEY TAKEAWAY • Today's lab build is the foundation for every Lab in this course.

Open-Source Lab Alternatives

- EVE-NG Community — browser-based network emulation
- Containerlab — Docker-based, very fast spin-up
- Mininet — pure software-defined network emulator
- Proxmox VE — bare-metal hypervisor for a serious home lab
- Cisco Packet Tracer — free for NetAcad students, lighter than GNS3
- All free, all production-grade, all in your reference link section

What's in Your Toolbox After Day 01

- CIA triad as a defensive mental model
- Working vocabulary of malware, network, social and app-layer threats
- Three crypto primitives — and when to use each
- Three frameworks — NIST, ISO 27000, CIS — with a cheat sheet
- Quantitative risk-assessment basics
- A lab environment (any of three platforms) ready for Labs 1-6
- Two artefacts started for your Course Procedure Manual (Lab 0)

KEY TAKEAWAY • If a friend asked "what is cybersecurity?" — you can now answer.

Heads-up — Day 02

- Identify and classify threats from simulated traffic and logs
- Risk-assessment mini-exercise (you'll re-use today's register)
- Lab Environments Practice across all three platforms
 - AWS Edu
 - VirtualBox
 - GNS3
- Bring your Day 01 reports — they are the prerequisite

KEY TAKEAWAY • Lab 1 is graded — show up with the lab environment already built.

Reminders & Logistics

- Mid-Term Exam — Day 07 • covers Days 1-6 • 20 % of grade
- Course Procedure Manual — Day 14 • 10 % of grade • 60 % final eval
- Final Exam — Day 15 • 30 % of grade
- Hands-on Labs — 6 × 5 % • 30 % of grade
- All exercises submit via Omnivox LEA Dropbox
- Late submissions: -10 % per calendar day
- Always verify external URLs through [virustotal.com](https://www.virustotal.com)
- Cybersecurity ethics — never test what you don't own without authorisation

KEY TAKEAWAY • Authorisation is the seatbelt of cybersecurity. Buckle up before every lab.

Reference Links (1/2)

- NIST — nist.gov
- NIST CSF 2.0 — nist.gov/cyberframework
- NIST SP 800-53 — csrc.nist.gov
- NIST NVD — nvd.nist.gov
- ISO/IEC 27001 — iso.org/standard/27001
- CIS Controls — cisecurity.org/controls
- CIS Benchmarks — cisecurity.org/cis-benchmarks
- CISA — cisa.gov
- MITRE ATT&CK — attack.mitre.org
- OWASP — owasp.org

Reference Links (2/2)

- AWS Educate — aws.amazon.com/education/awseducate
- VirtualBox — [virtualbox.org](https://www.virtualbox.org)
- GNS3 — gns3.com
- EVE-NG Community — eve-ng.net
- Containerlab — containerlab.dev
- Mininet — mininet.org
- Proxmox VE — proxmox.com
- VirusTotal URL scanner — virustotal.com/gui/home/url
- AlienVault OTX — otx.alienvault.com
- Have I Been Pwned — haveibeenpwned.com

Disclaimer (1/2)

- All Material is the exclusive intellectual property of Cyber.SoHo
- Cyber.SoHo is the sole creator and owner of these educational materials
- Provided for personal, educational, non-commercial use by enrolled students
- Reproduction, redistribution or use to train automated systems requires written authorisation
- Mentions of third parties are illustrative — no affiliation, sponsorship or endorsement implied
- Trademarks remain the property of their respective owners
- YouTube videos remain the property of their creators — referenced by URL only
- External links — verify on [virustotal.com/gui/home/url](https://www.virustotal.com/gui/home/url) before clicking

Disclaimer (2/2)

- Lab work — only against systems you own or have explicit written authorisation to test
- Never scan, probe or brute-force third-party networks, accounts or services
- Treat captured credentials, packets and data as strictly confidential
- Comply with: Spanish Código Penal art. 197bis ff., EU Directive 2013/40/EU,
 - Canadian Criminal Code s.342.1, US Computer Fraud & Abuse Act (CFAA) where applicable
- Tools mentioned are open or commercial — replaceable by equivalents
- All consequences of misuse are the SOLE responsibility of the student
- Cyber.SoHo, instructors and contributors decline any liability for misuse
- Curiosity is the engine of cybersecurity — authorisation is the seatbelt

END OF DAY 01

Questions?

Then off to the lab.

Submit Lab 0 by May 10, 23:59 EST

Omnivox LEA Dropbox

CYBER.SOHO

*From the Industry
to the Classroom*

*Building the IT's Future,
Today and Together!*